

2026 ANNUAL CYBER-THREAT REPORT

Post-Compromise Trends

In 2025, adversaries more often arrived with elevated privileges, blended into legitimate activity, and moved quickly from access to impact, making this phase the inflection point between containment and collapse.

In the sections that follow, we break down how attackers traded traditional privilege escalation to instead blind defenders through EDR impairment, established persistence through the registry, and moved laterally using legitimate protocols and virtual infrastructure—before monetization shifted further toward data theft, with exfiltration outpacing encryption.

Meanwhile, the malware that enabled these outcomes increasingly “won” by industrializing trust. Instead of relying on noisy exploits, top families blended into normal workflows using signed, legitimate-looking software, trusted system utilities, and search-to-download delivery that bypassed the inbox.

Attackers Enter with a Head Start



social engineering. From there, they immediately focused on persistence, stealth, and fast lateral movement—often within what looked like legitimate sessions.

When attackers start with elevated privileges, security teams must incorporate AI-assisted behavioral monitoring and fast investigation to detect abnormal activity within normal operations. And response must be fast enough to break the chain before lateral movement and data theft.

Attackers Trade Privilege Escalation for Entrenchment



Account Manipulation Turns Access into Ownership

Account manipulation rose into the top 3 privilege escalation techniques in 2025 as attackers shifted their focus from gaining admin access to keeping it. To establish persistence, adversaries used legitimate administrative functions (creating or modifying accounts) that blended into everyday IT noise.

In one observed incident, attackers authenticated to a firewall management interface, then used administrative privileges to create multiple new local users, and immediately added them to the VPN services group.

This deliberate escalation converted basic user accounts into powerful remote access. Even if the initial compromise vector had been addressed, the threat actors

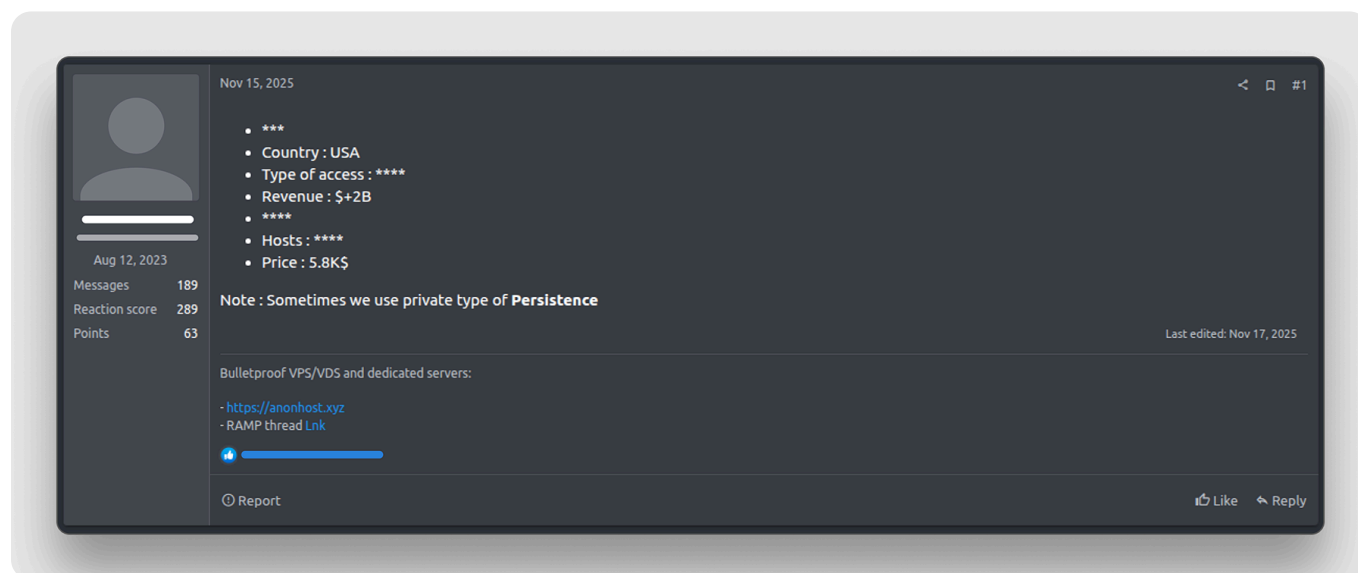
retained a legitimate-looking, high-privilege path back into the network. The only reliable sign of malicious activity was the timing: a sudden cluster of administrative authentications where none had existed before.

Domain Accounts and AD CS Weaponize Legitimacy

While account manipulation changes the environment to preserve access, valid accounts use existing privileges to move laterally without triggering alarms. This blurs the line between initial access and privilege escalation, and in some cases, likely erases it altogether.

Authentication with a valid, high-privileged domain account generates logs identical to standard business operations, making it difficult to distinguish between a sysadmin doing their job and an adversary staging and executing ransomware using the same credentials.

As in 2024, this technique's prevalence was fueled by an industrial-scale supply of compromised identities. Massive repositories of credentials are available for purchase on criminal marketplaces, and social engineering is still a reliable delivery path for infostealing malware like "Lumma" and "Oyster."



The pursuit of legitimate-looking access also shows up in Active Directory Certificate Services (AD CS) abuse, where misconfigured certificate templates allowed attackers to manufacture their own valid admin credentials. These forged certificates blend into normal activity, drastically cutting breakout time for attackers and leaving defenders who aren't collecting the right telemetry with less time to detect and respond.

ReliaQuest contributed to a May 2025 FBI Cybersecurity Advisory disseminating the “Lumma” infostealer’s known tactics, techniques, and procedures (TTPs). The advisory coincided with multiple domain seizures that disrupted Lumma’s activities.

The disruption likely created a gap in the availability of fresh credentials on underground markets, forcing threat actors to delay operations, seek alternative stealer variants like “Redline” or “Vidar,” or pay premium prices for existing access.



Take Action Against Privilege Escalation

- Monitor account modifications and service principle name (SPN) changes to catch unauthorized activity early.
- Strengthen credential hygiene by enforcing strong passwords, MFA, and regular account cleanup.
- Establish non-negotiable visibility for AD CS by logging specific Certification Authority codes and deploying hygiene hunt packages to catch certificate abuse.

Attackers Sabotage Defenses to Evade Detection



The Critical Window for Preventing Defense Impairment

In 2025, **55% of successful defense impairment targeted EDR agents**. The actions required to disable EDR and logging are high-signal (and detectable when telemetry and alerting are in place), but if the attacker succeeds, they can immediately degrade visibility and even erase evidence. This means defenders lose the context they need to stop what happens next.

In one engagement, an attacker deployed a malicious executable (`1dControl.exe`) that immediately disabled Microsoft Defender by modifying the `DisableAntiSpyware` registry key. With defenses down, the attacker ran credential harvesting tools, including Mimikatz, and cleared 1,000-plus PowerShell event logs using `wevtutil.exe` to systematically destroy forensic evidence. The incident progressed from initial compromise to credential theft in under an hour, reinforcing the fact that any attempt to disable EDR or tamper with logging should trigger an escalation response measured in minutes, not hours.

Attackers Rewire Windows for Evasion and Persistence

Windows Registry modification made the defense evasion short list in 2025 a native, low-friction, and effective way to achieve both defense evasion and persistence without deploying additional malware. By changing registry keys to

resemble routine admin activity, adversaries can survive reboots, weaken security controls, and quietly prepare systems for credential access and lateral movement.

Common Patterns in Windows Registry Modification This Year



Changing RemoteRegistry "Start" Settings to Enable Remote Credential Access



Manipulating Security Account Manager Registries to Support Credential Dumping



Flipping the fDenyTSConnections Terminal Services Key from "1" to "0" for Remote Access and Lateral Movement

In the campaign involving (1dControl.exe) , attackers also created suspicious driver service entries such as sysdiag and hrwfpdr that pointed to system32\DRIVERS , masquerading as legitimate services to persist across reboots. This "Living-off-the-Land" (LotL) approach is best countered with behavior- and change-based monitoring: Alert on high-risk registry modifications, tighten permissions on sensitive keys, and automatically correlate registry changes with follow-on activity (service creation, credential access, remote-access enablement) to catch and contain persistence attempts quickly.



Take Action Against Defense Evasion

- Monitor and protect EDR agents, antivirus solutions, and firewall configurations; enforce security service integrity; and alert on unauthorized changes or exceptions to security configurations.
- Audit registry keys for suspicious changes, restrict access to critical keys, monitor Remote Registry services, and enforce policies that prevent unauthorized modifications for persistence or defense evasion.
- Detect renamed executables and unusual file placements in system directories, verify process authenticity, and implement strict allowlisting policies to prevent attackers from mimicking trusted files.

Lateral Movement Through Native Protocols

2025 Customer Incidents

Lateral Movement Technique

Percentage of Incidents

RDP

24%

SMB

16%

SSH

10%

2024 Customer Incidents

Lateral Movement Technique

Percentage of Incidents

RDP

26%

Internal Spearphishing

16%

SSH & SMB / Windows Admin Shares

14%

RDP remained the top lateral movement technique in 2025 because of its ubiquity and its legitimacy as a native Windows feature. When attackers use stolen credentials to pivot via RDP, the traffic blends into normal remote administration and can be mistaken for authorized IT activity. Attackers extend the same “LotL” stealth

with Server Message Block (SMB)—using Windows admin shares and remote execution (e.g., PsExec-style activity) to move tools and payloads without interactive sessions—and with Secure Shell (SSH), using stolen keys or credentials to pivot through Linux, cloud, and container environments.

The difference is speed and context. Defenders need correlated identity, endpoint, and network telemetry to distinguish legitimate remote RDP/SMB/SSH administration from attacker-driven pivots and to quickly surface the pre- and post-connection behaviors that confirm malicious lateral movement.

Turning VMs into a Command Center

While the top 3 techniques dominated by volume, threat actors have also found success this year with a not-so-new tactic: virtual infrastructure. In 2025, 1 in 10 adversaries that achieved exfiltration or ransomware used a VM for lateral movement.

By spinning up new VMs or abusing existing virtual infrastructure, particularly older or decommissioned systems lacking current security controls, attackers achieve both mobility and concealment. These virtual environments often operate outside the scope of EDR coverage, giving attackers space to conduct reconnaissance, stage tools and malware, harvest credentials, and launch follow-on actions.

One Scattered Spider incident showed how damaging this can be. After conducting social engineering to gain access to privileged accounts, the attackers requisitioned the target's virtualization management console to deploy their unmonitored VMs. These "blind spots" served as a staging ground to attack domain controllers and compromise Privileged Access Management (PAM) systems. This allowed them to harvest the organization's most sensitive credentials and monitor internal communications, all while operating from a command center built within the victim's own network.

The lesson is practical: Attacker-controlled VMs can become stealth staging grounds that operate outside traditional visibility. Adversaries can run reconnaissance, delete security alerts, and maintain persistence via unremediated service principals while staying outside traditional visibility. That's why the practical priority is to correlate across virtualization, identity, and endpoint telemetry so VM creation, vCenter

access, privileged role changes, and suspicious service principal activity are investigated as one campaign, and not dismissed as routine admin noise.



Take Action Against Lateral Movement

- Enforce strong credential policies, implement MFA for RDP access, monitor remote session activity, and restrict RDP usage to trusted IP addresses and administrative accounts.
- Enforce application control policies to prevent the installation or execution of unauthorized RDP tools.
- Use MFA for SSH, rotate and secure SSH keys, monitor for unusual SSH activity, and restrict access to critical systems to protect Linux and cloud environments.

Exfiltration Eclipses Encryption in a 6-Minute Sprint

2025

Customer Incidents

Exfiltration Technique

Percentage of Incidents

Exfiltration Over Web Service

42%

Exfiltration Over Other Network Medium

27%

Automated Exfiltration

9%

2024

Customer Incidents

Exfiltration Technique

Percentage of Incidents

Exfiltration Over Web Service

36%

Exfiltration Over Alternative Protocol

14%

Exfiltration Over C2 Channel

14%

The window to stop data theft is getting narrower. In 2025, the quickest time-to-exfiltration was just 6 minutes—compared with 19 minutes for encryption. By avoiding the technical complexities of encryption, attackers have embraced data exfiltration as the most direct path to speed, impact, and leverage.

2025

Fastest Exfiltration

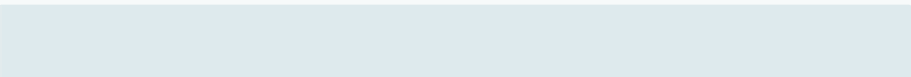


Fastest Encryption

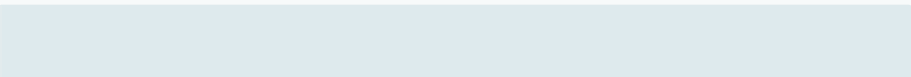


2024

Fastest Exfiltration



Fastest Encryption



This speed points to the automation of the “smash-and-grab” phase. Fueled by a surge in automated exfiltration tools, attackers are moving from manual keyboard activity to AI-assisted scripts that parse and exfiltrate high-value data faster at

machine speed. At that pace, manual triage becomes a lagging indicator: If defenders are waiting for an analyst to review an alert, the data is already gone.

The economics reinforce the shift. Similar to 2024, in all incidents where impact was observed, 79% involved data exfiltration, while 28% also included encryption. As organizations get better at restoring systems, and often choose to rebuild rather than pay, encryption has become a less reliable pressure tactic, forcing attackers to shift focus to what cannot be restored: confidentiality.

Cloud Exfiltration Without the Noise or Block Button

To achieve this velocity without triggering alarms, attackers often exfiltrate through legitimate web services like OneDrive and GitHub. They know most organizations can't simply block these platforms without disrupting business. This limits defenders' ability to be proactive, forcing them to rely on difficult-to-tune behavioral monitoring rather than proactive blocking.

Newly emerged extortion group "Crimson Collective," who target high-profile IP- and cloud-based data, recently executed this strategy. In one case we investigated, the attackers used a legitimate file transfer application and compromised IAM credentials to siphon critical assets, from Kubernetes backups to 11GB database exports, directly from AWS S3 buckets. Because the traffic was encrypted via HTTPS and used valid cloud storage APIs, hundreds of operations blended into normal traffic.



The Double-Edged Sword of Network Exfiltration

While web services dominated as the primary exfiltration path, attackers still used direct C2 channels and alternative infrastructure to funnel data directly to their own systems. This method carries higher detection risk than cloud platforms, but it offers attackers greater control over the stolen data.

Regardless of the channel, it's critical to monitor egress traffic with the same rigor as ingress. And at the first sign of exfiltration, you need AI-driven prevention capable of detecting and blocking data theft at machine speed.



Take Action Against Exfiltration

- Monitor traffic to cloud platforms, implement advanced alerting for unusual uploads, and enforce strict access controls to detect and prevent stealthy data exfiltration.
- Monitor direct connections to external infrastructure, analyze outbound traffic patterns, and deploy network segmentation to limit attackers' ability to exfiltrate data via C2 channels.
- Detect and block suspicious scripts, monitor rapid data transfers, and implement real-time alerts to identify automated exfiltration attempts and minimize response time.

Your Strategy for Combatting Post-Compromise Techniques

Attackers are compressing the post-compromise timeline. They're landing with high privileges, blending into legitimate activity, and moving laterally before human-led triage can catch up. Organizations need adaptive defenses that combine autonomous investigation with rapid containment to identify and disrupt suspicious account activity, endpoint tampering, and early lateral movement before they escalate into ransomware or large-scale data loss.

Accelerate Investigations with Agentic AI

While defenders are slowed by manual triage and fragmented visibility across identity, endpoint, cloud, and SIEM tools, attackers can move from one system to many in minutes. To move at the speed of the threat, organizations must incorporate agentic AI that can run end-to-end investigations.

- ✓ **Hand off repetitive, time-consuming investigations:** Use agentic AI to plan and execute investigations for post-compromise signals (e.g., privileged group adds, MFA resets, VPN account creation, EDR tampering, and registry persistence). AI pulls the right telemetry and enriches artifacts (users, IP addresses, hosts) on analysts' behalf. It also ensures consistency, retaining environment-specific context and incorporating feedback with transparency and governance.
- ✓ **Reduce false positives without losing explainability:** Apply historical and environment context to filter noise and flag the account changes that matter (e.g., unusual SPN manipulation, new shadow admins, and abnormal session patterns) while keeping investigation steps transparent so teams can validate and tune based on real outcomes.
- ✓ **Stay current on emerging campaigns:** Continuously update agentic memory with the latest threat intelligence and observed tradecraft so investigations look beyond static IOCs and flag behavior consistent with new or evolving campaigns, even as attacker infrastructure and payloads change.

Disrupt Post-Compromise Progression with Automated



Response

When attackers increasingly land with high privileges and move quickly to persistence and lateral movement, automated response can be the difference between a contained incident and an enterprise-wide breach. GreyMatter customers can use the following Automated Response Playbooks aligned to the post-compromise patterns covered in this section:

- ✔ **Disable User:** Immediately revokes attacker-controlled accounts to stop “access-to-ownership” tactics (including shadow admin creation, privileged group additions, and other account manipulation that can blend into routine IT operations), before they become durable persistence.
- ✔ **Terminate Sessions and Reset Passwords:** Interrupts valid-account abuse by ending active sessions across multiple tools and forcing credential resets after credential theft or suspicious MFA activity is detected. This prevents attackers from impersonating admins and pivoting quietly through the environment.
- ✔ **Isolate Host:** Quarantines compromised endpoints at the first sign of post-exploitation (e.g., credential dumping, registry-based persistence, reconnaissance/scanning), preventing lateral movement and buying critical time to investigate and remediate before ransomware or exfiltration begins.

Industrialized Trust and the Latest Malware Attack Chains

2025

Customer Incidents

Malware Variant

Percentage of Incidents

Baoloader

18%

Oyster/BroomStick

10%

Shai-Hulud

6%

2024

Customer Incidents

Malware Variant

Percentage of Incidents

SocGholish

23%

AsyncRAT

7%

Lumma

5%

The 2025 malware landscape proved that effective detection must center on behavior, execution paths, and identity outcomes. We saw malware follow 3 clear “lanes” of success: “BaoLoader,” which pairs AI-assisted development with signed, utility-like software and fileless persistence to undermine traditional trust signals; Oyster, which uses search engine optimization (SEO) poisoning and malvertising to intercept software downloads and then hides behind legitimate Windows utilities; and “Shai-Hulud,” a self-replicating supply-chain worm that hijacks legitimate npm maintainer accounts, turning software updates into credential theft and sabotage.

The numbers reinforce the shift away from the inbox: In 2025, 70% of malware arrived via SEO poisoning and malvertising, nearly double the rate of traditional phishing. Instead of fighting hardened email defenses, attackers catch users at the moment of intent, i.e., when they’re searching for software or corporate portals and are least likely to scrutinize URLs, making “search-to-download” a reliable delivery system.



of malware arrived via SEO poisoning and malvertising

The AI-Written Trojan: BaoLoader's Rise to Dominance

Late in 2025, BaoLoader, associated with the broader “EvilAI” campaign, rocketed to the top of our malware charts. Previously unseen in the malware landscape, it reflects the first major convergence of [AI-assisted development](#), social engineering, and traditional cybercrime.

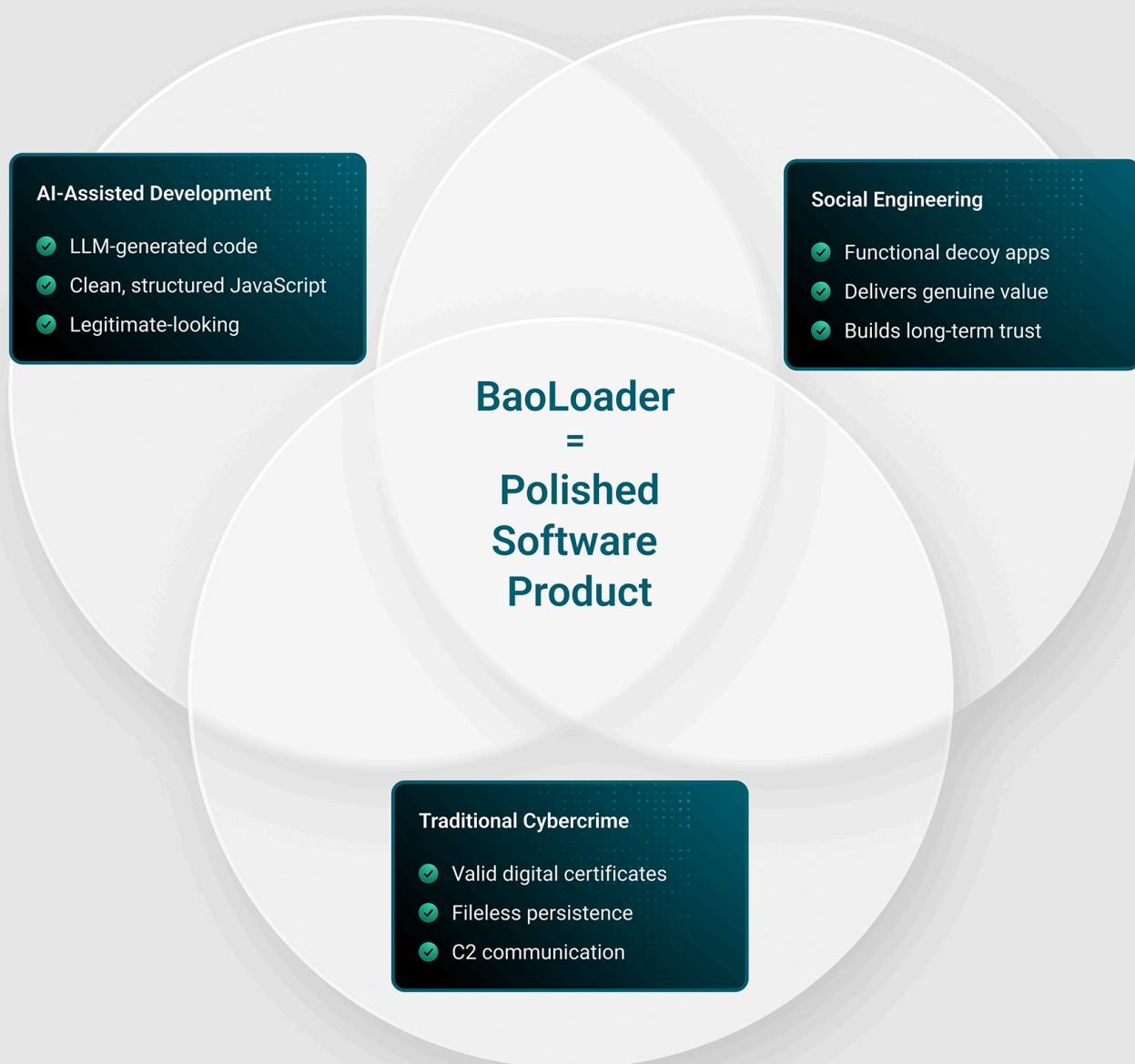
Instead of scrambling code to look malicious like traditional malware, BaoLoader uses large language models (LLMs) to produce clean, structured, legitimate-looking JavaScript. It arrives wrapped in fully functional software—like malicious PDF editors or recipe listers—that works exactly as advertised.

This “utility-first” approach builds long-term trust and can keep the implant in place on the network for months. Combined with valid digital certificates, it becomes a threat trusted by the user, authorized by the operating system (OS), and ignored by antivirus. In other words, it breaks the foundational assumption that “useful software signed with a valid certificate is safe.”

By masking its payload with valid digital signatures, AI-generated code, and fileless persistence, BaoLoader effectively undermines traditional trust models and forces defenders to judge intent and behavior, not just file structure or signatures.

What does work for defense is focusing on execution and outcome. That means behavior-based detection, tighter controls on scripting and trusted-process abuse, and allowlisting based on known publishers and expected application behavior. Organizations must treat reputation as a starting point, not a verdict, and monitor for post-install behavior that doesn't match the application's stated function, even when the application appears legitimate.

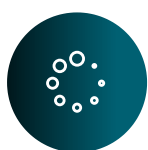
BaoLoader: The Perfect Storm



COM Hijacking Enables Fileless Persistence with Minimal Noise^a

One incident we investigated exemplified the Baoloader playbook. It began with a social engineering lure: a JavaScript file disguised as “2017 Lexus RX 350 Maintenance Schedule.” When the user executed the file, they received the legitimate document—while the malware silently deployed an obfuscated PowerShell payload from `C:\ProgramData\`.

Instead of relying on noisy persistence mechanisms (like Run Keys or scheduled tasks), which standard EDR tools easily catch, BaoLoader used Component Object Model (COM) hijacking to target Internet Explorer class identifiers (CLSIDs) in the registry, effectively tricking Windows into loading the malware every time the browser was launched. It survived reboots without creating obvious startup items and operated entirely in memory. We confirmed infection through behavioral monitoring of C2 callbacks, where the malware boldly reported its success: `script: startup_typelib, status: OK`.



Take Action Against BaoLoader

- Establish and maintain a centralized, IT-approved repository of administrative tools with hash verification. Enforce policies that restrict administrators from downloading utilities from external sources.
- Implement network-layer protections that block connections to newly registered domains and data center–hosted IP addresses commonly used in malvertising campaigns.
- Do not inherently trust code-signing signatures; instead, maintain a vendor allowlist of known, approved publishers and products. Flag or

block binaries signed by newly encountered publishers pending security review.

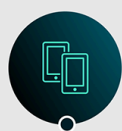
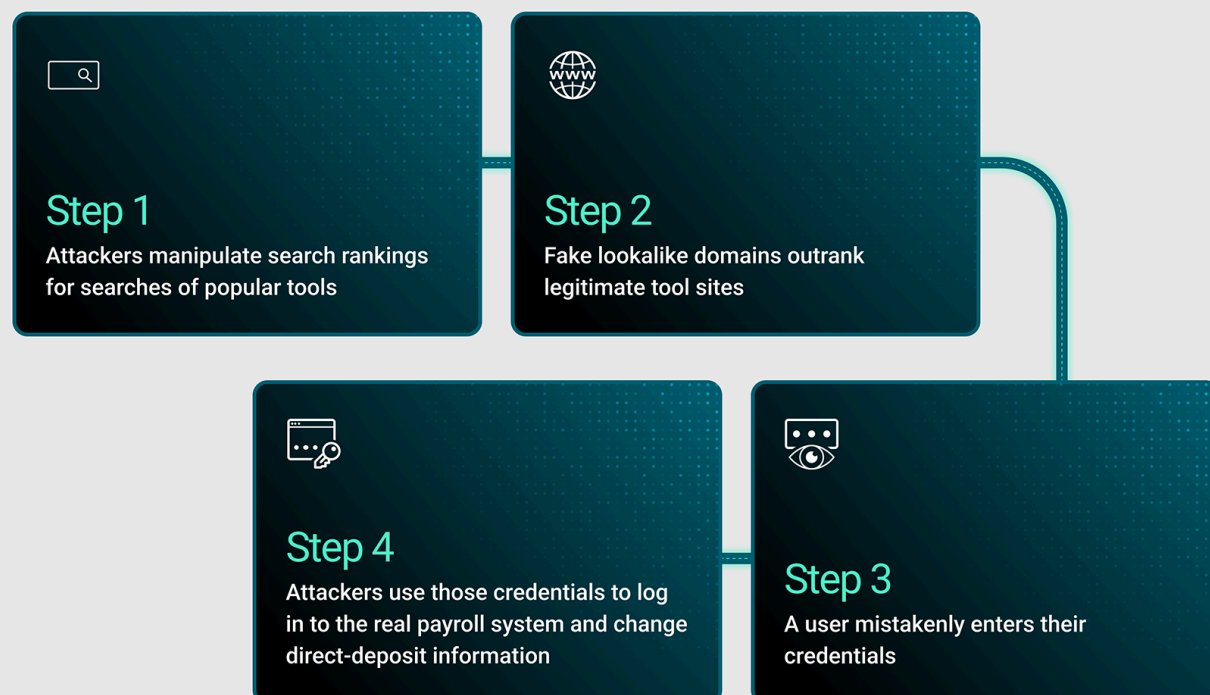
Oyster Exploits the IT Team's Toolkit

BaoLoader achieved success through AI-driven novelty, but Oyster (aka "Broomstick" or "CleanUpLoader"), on the other hand, found success through stealth and precision. Most malware spreads opportunistically, but we repeatedly saw Oyster specifically target IT professionals and developers, meaning it compromised higher-privilege accounts from the start.

Active since July 2023, Oyster's momentum in 2025 was driven by affiliate-led distribution through malvertising and SEO poisoning. Threat actors manipulated search rankings so attacker-controlled lookalike sites surfaced prominently for common searches of popular software tools, such as "PuTTY download" or "install VPN," often targeting tools used by high-privilege users.

Malvertising complemented this tactic by placing malicious ads above organic results on search engines, capitalizing on users' tendency to click the first sponsored link.

SEO Poisoning: How Oyster Cashes in on Payroll



Mobile Devices Amplify Risk

Unprotected by DNS filtering or traffic monitoring

Lack logging and endpoint visibility required for effective investigation and remediation

Once inside, Oyster isn't just a single-purpose dropper. It acts as both a lightweight loader for additional tools and a full-featured remote-access trojan (RAT) that maintains control.

In one Oyster incident we investigated, the attack didn't start with a malicious executable. Instead, the user (likely an IT staffer) executed `mshta.exe`, a legitimate Windows component, that retrieved content from an obfuscated URL. To most security tools, this looked like a system administrator running a routine script. In reality, the URL delivered `proxy.dat`, a VBScript dropper that quietly launched a hidden PowerShell window to pull the final payload. By chaining `mshta.exe` (download) and PowerShell (execution), the attackers abused trusted, digitally signed Windows tools to bypass signature-based security entirely.

Oyster also weakens file reputation as a control. When attackers weaponize the tools IT teams use every day, defenders need AI-driven behavioral analytics to correlate behavior. Organizations must restrict how tools like `mshta.exe` communicate (for example, blocking external network connections where feasible) and enforce strict oversight of high-privilege accounts most likely to be targeted.

Mobile Devices Amplify Risk

SEO poisoning tactics like those used by Oyster are extra effective on mobile devices. Without protections like DNS filtering or traffic monitoring, phone-based searches increased the likelihood of success—and personal devices usually lack the logging and endpoint visibility required for effective investigation and remediation.

[In one incident we investigated](#), employees searching for their payroll portal were routed to a fake SEO-poisoned site that outranked the legitimate page. After users entered their credentials, attackers used the stolen credentials to log in to the real payroll system and changed direct-deposit information.

A single malicious domain, particularly when accessed on a mobile device, can sidestep the filters that restrict email campaigns and scale to hundreds or thousands of victims. By using malware that masquerades as legitimate IT software, attackers increase the odds of compromising high-privilege users, producing higher-value credentials for resale and enabling quieter lateral movement.

The susceptibility of mobile devices to this type of malware means your defense must extend beyond email attachments and links: Prioritize DNS and web content filtering, browser protections, and coverage for mobile and Bring Your Own Device (BYOD) search-to-download activity.



Take Action Against Oyster

- Change the default script executor for JavaScript (**.js**) and VBScript (**.vbs**) files to Notepad through Group Policy to prevent automatic execution of malicious scripts delivered via SEO poisoning.
- Deploy PowerShell Constrained Language Mode to limit scripting capabilities to a safer subset of functionality. This stops attackers exploiting dangerous operations and executing malicious scripts.
- Use Group Policy to enable PowerShell logging, including script block logging and transcription.

The Self-Replicating Worm: Shai-Hulud's Supply-Chain Carnage

First observed in September 2025, Shai-Hulud quickly rose to become the 3rd most prevalent malware family, showing how attackers can weaponize trusted maintainer accounts and routine software updates to achieve outsized impact.

Unlike traditional malware that targets a single endpoint, Shai-Hulud exploits the interconnected nature of modern software development, meaning a single compromised package can attempt to spread into thousands of dependent projects.

In the cases we tracked involving Shai-Hulud, threat actors used phishing campaigns disguised as official npm security alerts to steal maintainer credentials. Once inside those accounts, they poisoned trusted packages. Developers became infected through normal actions like running routine updates or executing standard CI/CD pipelines, without realizing libraries they'd used for months had been silently tampered with.

Invisible Execution and Exponential Spread Through Borrowed Trust

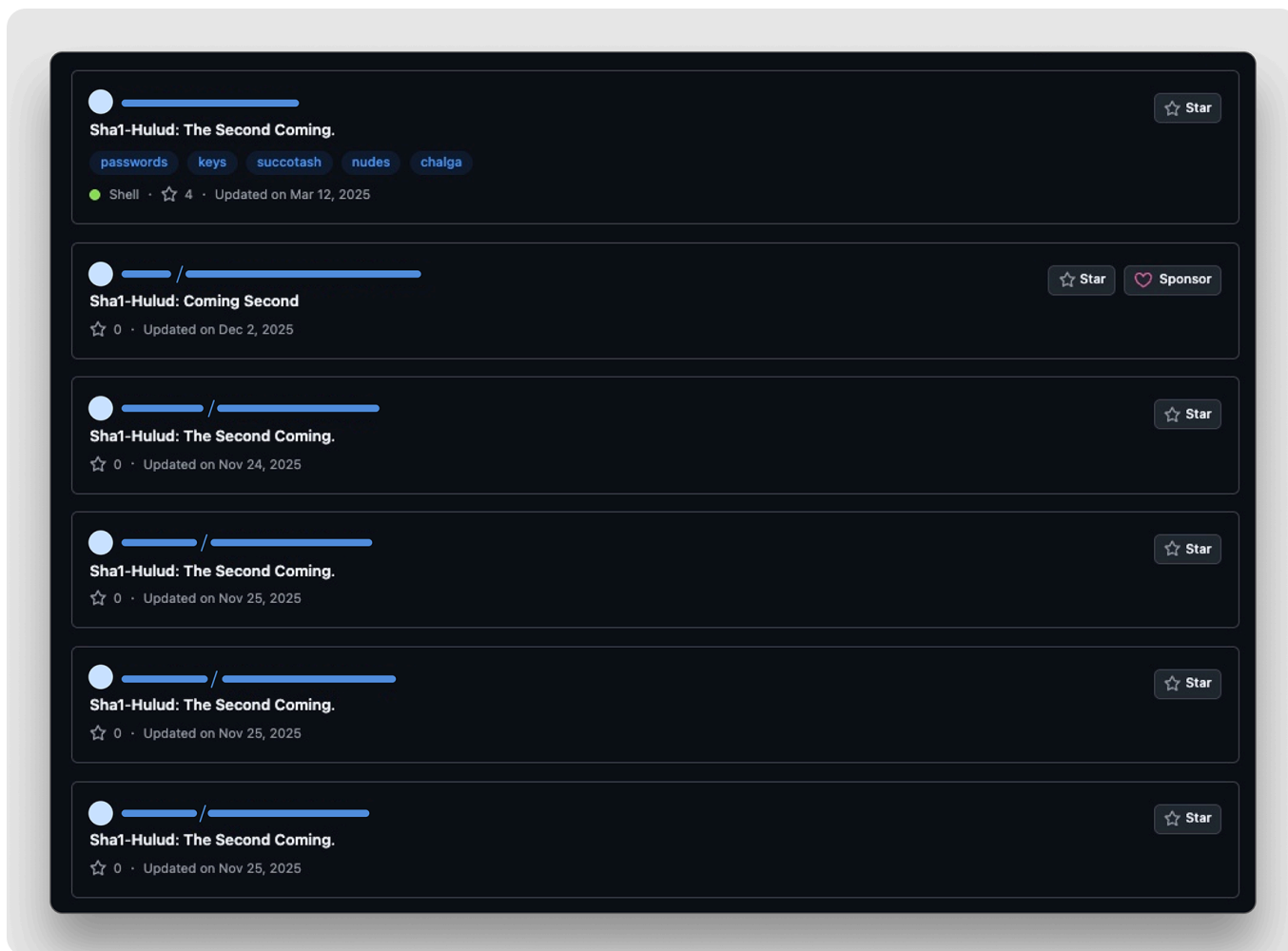
Shai-Hulud's effectiveness comes down to when it executes and how it spreads.

In one observed incident, it ran early in the install process, before security checks, reviews, or CI guardrails could catch it. To developers, everything looked normal: The package installed successfully while Shai-Hulud quietly launched its payload in the background.

Once active, it went after high-impact credentials: npm tokens, GitHub access tokens, SSH keys, and cloud credentials (AWS, Azure, and Google Cloud). It also leveraged TruffleHog, a legitimate secrets-scanning tool, to harvest sensitive information from local files and environments. Stolen data was pushed to newly created public GitHub repositories, effectively publishing secrets in plain sight.

A “2.0” wave just months later added a destructive twist: If credential theft failed, the malware attempted to wipe the victim's home directory, turning theft into sabotage.

The business risk of Shai-Hulud is cascading. The cloud credentials, API keys, and GitHub tokens that Shai-Hulud steals can directly unlock production environments, CI/CD pipelines, and proprietary source code. With this access, the attackers can move on to lateral movement, data exfiltration, and intellectual property theft, with potential follow-on ransomware deployment across the entire software development infrastructure.



** GitHub repositories used by Shai Hulud to exfiltrate and host sensitive data.*

Developer Machine Compromised During Routine Package Installation

In November 2025, we investigated a particularly insidious Shai-Hulud incident where the software supply chain was the delivery mechanism, requiring no direct targeting or social engineering against the organization.

A developer at a major enterprise installed `@asynccapi/modelina@5.10.3` using `pnpm` as part of routine work. The package installed cleanly with no visible errors, and the developer continued working, unaware of the compromise.

EDR telemetry revealed the infection occurred during the preinstall phase, before security checks could intervene. The malicious code executed through a legitimate, signed `Node.js` binary while the user performed normal development activities, downloading tools from internal repositories, installing related dependencies (including `@asynccapi/parser`), and using shell completion helpers. The compromised package

then triggered credential harvesting and attempted exfiltration to GitHub infrastructure.

Shai-Hulud operates on a pattern. It hijacks a legitimate maintainer account, poisons a trusted package, executes early in the installation lifecycle, and hides inside normal developer workflows. In other words, organizations can be compromised through routine software maintenance—without anyone even clicking a suspicious link.



Take Action Against Shai-Hulud

- Implement dependency pinning and lockfile validation in all CI/CD pipelines to prevent automatic installation of newly published package versions during routine builds.
- Enforce MFA with hardware security keys for all npm and GitHub accounts, particularly for package maintainers, to prevent phishing-based account takeovers that enable supply-chain poisoning.
- Deploy runtime monitoring for pre-install and post-install scripts to detect and block malicious code execution during package installation, before credential harvesting can occur.

Your Strategy for Combating Malware Threats

A malware intrusion can pivot into credential theft, persistence, and lateral movement in minutes, turning a single compromised host into an environment-wide

incident. Preventing escalation requires two things working together:

1. Faster, at-source detections that surface malicious behavior where telemetry is generated (endpoints, cloud, and SaaS)
2. Workflow orchestration that removes friction from approvals, handoffs, and cross-team coordination so response doesn't stall while attackers advance

Stop Malware Escalation with At-Source Detection

Malware campaigns move quickly from execution to credential theft and lateral movement, so detection speed matters. Cut time to detect by running detections where the telemetry lives—on endpoints, cloud platforms, and SaaS applications—without waiting on SIEM ingestion